
**MADICARE CONNECT (PTY) LTD
INFORMATION SECURITY COMPLIANCE
PROGRAM OVERVIEW**

Classification	: Internal
Version	: 1.0
Date	: June 2025
Author	: Patrick Vumuzi Mohlala
Review Date	: June 2026

1. EXECUTIVE SUMMARY

Medicare Connect (PTY) Ltd processes sensitive patient health information daily across its Johannesburg operations.

This compliance program establishes the foundation for an Information Security Management System (ISMS) aligned to ISO 27001: 2022 and The Protection of Personal Information Act (POPIA).

The program aims to :

- Protect Patient Confidentiality
 - Endure Integrity of Medical records
 - Maintain Availability of health systems
 - Meet South African legal requirements
 - Prepare the organization for ISO 27001 certification within 18Months
-

2. ORGANIZATIONAL PROFILE

Company	: Medicare Connect (PTY) Ltd
Registration	: 2018/234567/07
Industry	: Private Healthcare services
Employees	: 45 (30 Clinical , 15 admin/IT)
Location	: Sandton, Johannesburg
Website	: www.midicareconnect.co.za

Services Provided :

- In-person patient consultation
- Telehealth Video Consultations
- Online appointment Management
- Digital appointment management
- Digital patient record storage
- Laboratory result Integration
- Pharmacy prescription management

3. SCOPE OF INFORMATION SECURITY MANAGEMENT SYSTEM (ISMS)

This Information Security Management System (ISMS) covers all information assets, systems and processes used to :

IN SCOPE :

- Patient Health Record System (PHRS)
- Telehealth Platform (Microsoft Teams)
- Appointment Booking Portal
- Staff Laptops (35 devices)
- Mobile Devices used for consultations
- Email systems (Microsoft 365)
- Internal HR and payroll system
- Network Infrastructure (Sandton Office)
- Third Party Lab integration system
- Cloud storage (sharePoint/Onedrive)

OUT OF SCOPE

- Personal Devices not used for work
- Physical Building security system
- Pharmacy partner internal systems

4. INFORMATION ASSETS IDENTIFIED

CRITICAL ASSETS :

- Patient Medical Record database
- Patient Personal Information (POPIA)
- Clinical diagnosis and treatment data
- Staff personal Information
- Financial and Billing Records
- Login credentials and access keys

SYSTEMS AND PLATFORMS :

- Patient Health record System
- Microsoft 365 (Email and teams)
- Appointment Booking Portal
- Laboratory integration API
- Accounting software(sage)
- HR management system

5.REGULATORY REQUIREMENTS

POPIA (Protection Of Personal Information Act) :

- All patient data is personal Information
- Special personal information (Health data) requires heightened protection

- Breach notification required within 72 hours to Information Regulator
- Information Security must be appointed
- Third Party Processors need written contracts

National Health Act 61 of 2003:

- Patient confidentiality is mandatory
- Medical records must be retained for minimum 6 years
- Patient consent required for data sharing

ISO 27001:2022 :

- Information Security Management system
- Risk Assessment and Treatment
- Annex A controls Implemented
- Continuous improvement required

6.CURRENT MATURITY ASSESSMENT

MATURITY SCALE :

- Level 1 - Initial (Ad hoc , undocumented)
- Level 2 - Developing (Some processes exists)
- Level 3 - Defined (Documented Process)
- Level 4 - Managed (Measured and controlled)
- Level 5 - Optimized (Continuously improving)

CURRENT MATURITY BY DOMAIN :

Information Security Policies	: Level 1
Assets Management	: Level 2
Access Control	: Level 2
Cryptography	: Level 1
Physical Security	: Level 2
Operations Security	: Level 1
Communications Security	: Level 2
Supplier Relations	: Level 1
Incident Management	: Level 1
Business Continuity	: Level 1
Compliance (POPIA)	: Level 2

-OVERALL MATURITY : LEVEL 1-2 (DEVELOPING)

-Target Maturity in 18 Months : Level 3-4

7.COMPLIANCE PROGRAM GOALS

SHORT TERM (0-6 Months) :

- Appoint Information officer (POPIA)
- Document all Information assets
- Write core Security Policies

- Implement multi-factor Authentication
- Conduct staff security awareness training
- Establish incident response procedure

LONG TERM (12 Months) :

- Archive ISO 27001:2022 Certification
- Attain POPIA full Compliance
- Establish continuous improvement cycle
- Conduct External Audit

8. KEY ROLES AND RESPONSIBILITIES

CEO/Director :

- Overall accountability for ISMS
- Approved Security Policies
- Provide Resources for compliance

Information Officer (POPIA) :

- POPIA compliance oversight
- Liaison with information regulator
- Breach notification responsibility

IT Manager :

- Technical control implementation
- System access management
- Security Monitoring

Grc Analyst :

- Policy Documentation
- Risk assessment coordination
- Audit preparation and evidence collection
- Compliance tracking and reporting

ALL Staff :

- Follow security policies
- Report security incidents
- Complete security awareness training

9. TOP 5 GAPS IDENTIFICATION

GAP 1	: No Information Security Policy
Severity	: CRITICAL
POPIA/ISO Reference	: ISO Clause 5.2 / POPIA S19
Current state	: No formal policy exists
Remediation	: Draft and approve master information Security policy
Timeline	: Immediate (Month1)

GAP 2	: No Information Officer Appointed
Severity	: CRITICAL
POPIA/ISO Reference	: POPIA SECTION 55
Current state	: NO Designated officer
Remediation	: Appoint and register Information officer with Information Regulator
Timeline	: Immediate (Month1)
GAP 3	: No Multi-Factor Authentication
Severity	: High
POPIA/ISO Reference	: ISO Annex A.8.5
Current state	: Single Password only
Remediation	: Enable MFA on Microsoft 365 and Patient health record systems
Timeline	: Month 1-2
GAP 4	: No Incident Response Procedure
Severity	: High
POPIA/ISO Reference	: ISO Annex A.5.26 / POPIA Section 22
Current State	: No Formal Procedure
Remediation	: Write and test Incident response plan Including 72-hour POPIA notification
Timeline	: Month 2-3
GAP 5	: No staff Security Awareness Training
Severity	: High
POPIA/IOS Reference	: ISO Annex A.6.3 / POPIA Section 19(2)
Current State	: No training programme
Remediation	: Develop and Deliver annual Security awareness training to All 45 staff
Timeline	: Month 3

10. NEXT STEP

1. Present this overview to Management
 2. Get sign-off on compliance program
 3. Begin risk assessment process
 4. Start policy documentation
 5. Schedule Information officer appointment
-

Document Control

Version	:1.0
Prepared by	: Patrick Vusumuzi Mohlala
Date	: June 2025
Status	: Draft - Pending Approval
Next Review	: June 2026
